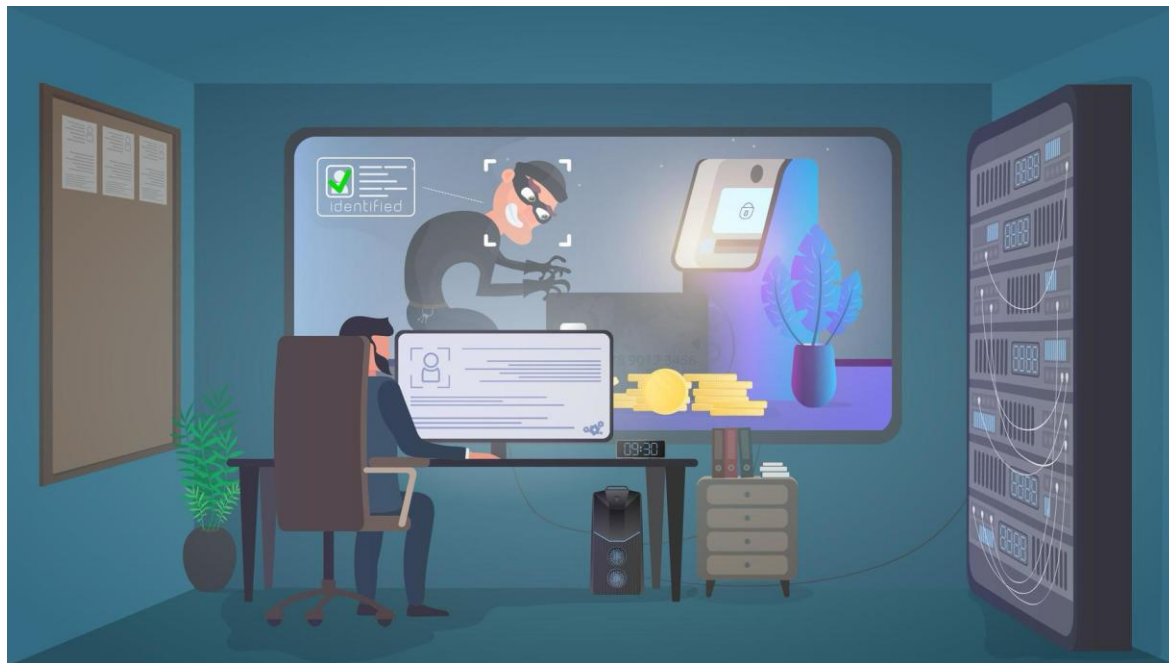




7. IDS

Garrison Gao

garrison.gao@uwa.edu.au

IDS

- ◇ In today's connected world, your business data is always at risk. Attackers are constantly looking for:
 - ◇ Weak passwords.
 - ◇ Open ports.
 - ◇ Outdated software.
 - ◇ Unprotected systems.
 - ◇ Employees who click unsafe links.
- ◇ Without an IDS, these threats can go unnoticed until the damage is done. But with an IDS, you get real-time visibility and warnings, so you can stop threats before they spread.

<https://www.cyberarrow.io/blog/what-are-intrusion-detection-systems/>

IDS

- ◇ Intrusion Detection System
- ◇ It looks for digital intruders trying to break into your systems
- ◇ Means to identify intrusions



IDS

- ◆ Intrusion is...
 - ◆ A set of actions that compromises CIA
 - ◆ Actions include
 - ◆ Unusual login attempts from foreign IP addresses.
 - ◆ Malware trying to send data outside your network.
 - ◆ Changes to sensitive files or programs.
 - ◆ Large amounts of traffic flooding your server.
 - ◆ Unusual user behavior, like accessing data at odd hours.

IDS

- ◇ Intrusion detection is...
 - ◇ Detecting signs of security problems and analysing the events happening in a computer/network systems
 - ◇ So data is important
 - ◇ Security Events
 - ◇ Firewall logs, endpoint security logs, threat intelligence etc
 - ◇ Network
 - ◇ Proxy/web filtering logs, network traffic, switches, DNS router/server, etc
 - ◇ Applications and devices
 - ◇ End user laptops or desktops (e.g., windows event logs), AD logs, web applications, databases, etc

IDS

- ◇ Intrusion detection is...
 - ◇ Detecting signs of security problems and analysing the events happening in a computer/network systems
 - ◇ We assume that system activities (e.g., users, program) can be monitored
 - ◇ Steps
 1. Monitor – analyse hosts/networks
 2. Identify – any misuse/abnormal activities
 3. Assess – severity and alert administrators

IDS

- ◇ Intrusion detection system is...
 - ◇ Combinations of software and hardware to perform intrusion detection
 - ◇ Can be placed in multiple locations in the network



IDS

- ◆ Detect intrusion from (Types)

- ◆ Networks (i.e., NIDS)
- ◆ Hosts
- ◆ Application
- ◆ Hybrid

- ◆ ID models (methodology)

- ◆ Misuse detection
 - ◆ Signature or knowledge-based
- ◆ Anomaly detection
 - ◆ Behaviour or statistic-based



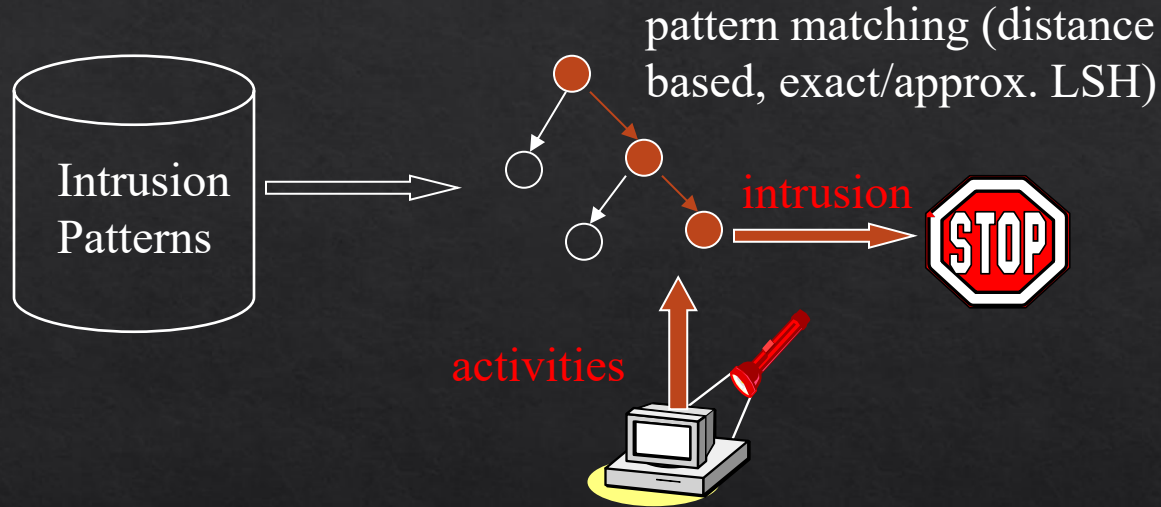
IDS

- ◇ Misuse detection
 - ◇ Well-known attack signatures are stored in the database
 - ◇ Current audit trails are compared with stored signatures
- ◇ Anomaly detection
 - ◇ Identify deviation from normal usage pattern
 - ◇ Apply statistical measures to classify activities/behaviours

Misuse Detection

- ◇ Find network, host traffic patterns that match known signatures
- ◇ Advantage:
 - ◇ Many attacks have distinct signatures
- ◇ Disadvantages:
 - ◇ IDS's signature database must be updated to keep pace with new attacks
 - ◇ Malicious code authors intentionally use tricks to fool these IDSs (e.g, rewritten a small fraction of code, insert NOP during compiling)

Misuse Detection



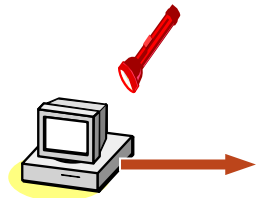
Example: *if* (src_ip == dst_ip) *then* "LAND attack"

Can't detect new attacks

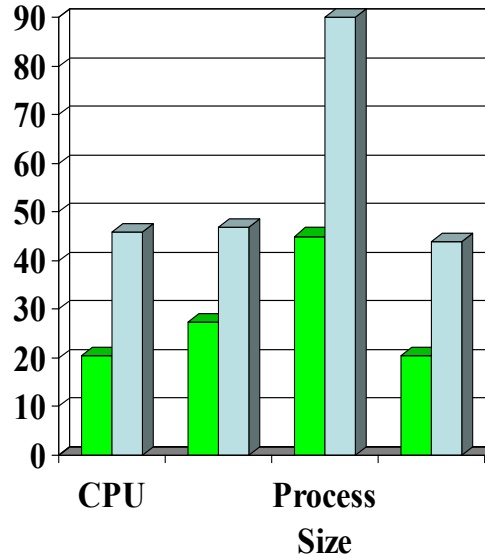
Anomaly Detection

- ◇ Statistical anomaly-based IDS sample network activity, compare to “known normal” traffic
- ◇ IDS sounds alarm when activity is outside baseline parameters
- ◇ Advantage:
 - ◇ IDS can detect new types of attacks
- ◇ Disadvantages:
 - ◇ Requires more overhead, compute power than signature-based IDSs
 - ◇ May generate many false positives

Anomaly Detection



activity
measures



probable
intrusion



Usually have (high) false positive rate -
anomalies can just be new normal activities.

IDS Terminology

- ◇ Alert, alarm : self-explanatory
- ◇ False negative : IDS fails to detect actual attack
- ◇ False positive : Attack alert when none occurred
- ◇ Confidence value : Estimate of attack probability
- ◇ Alarm filtering : self-explanatory

Key Performance Metrics

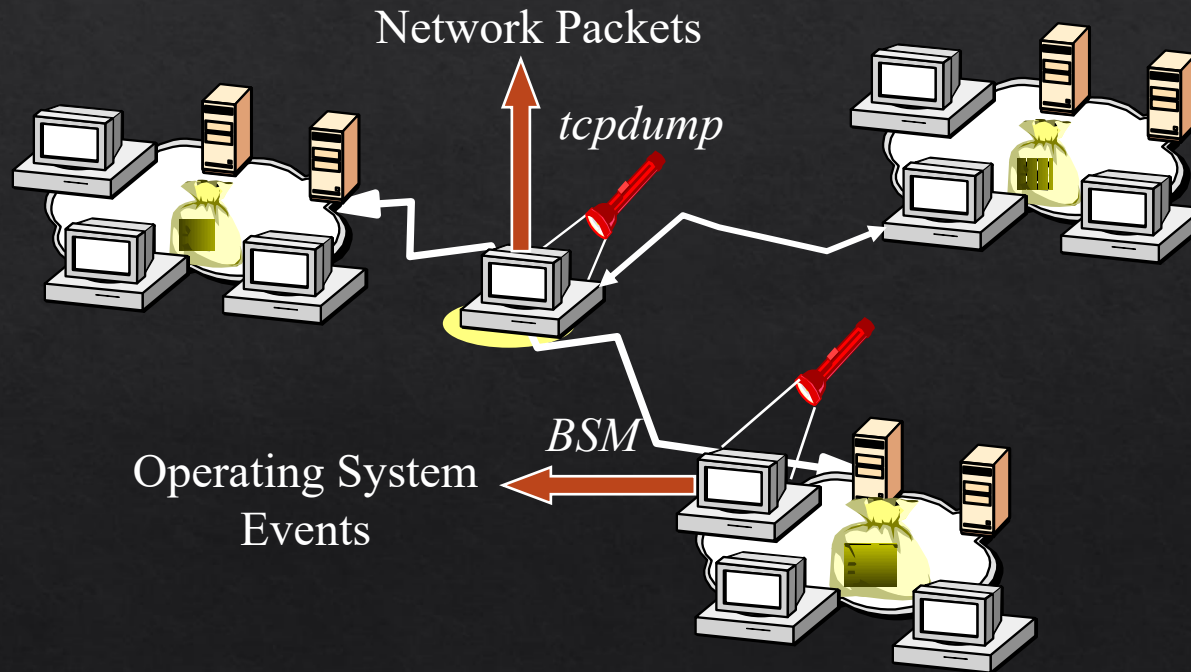
- ◇ Algorithm

- ◇ Alarm: A; Intrusion: I
- ◇ Detection (true alarm) rate: $P(A | I)$
 - ◇ False negative rate $P(\neg A | I)$
- ◇ False alarm rate: $P(A | \neg I)$
 - ◇ True negative rate $P(\neg A | \neg I)$

- ◇ Architecture

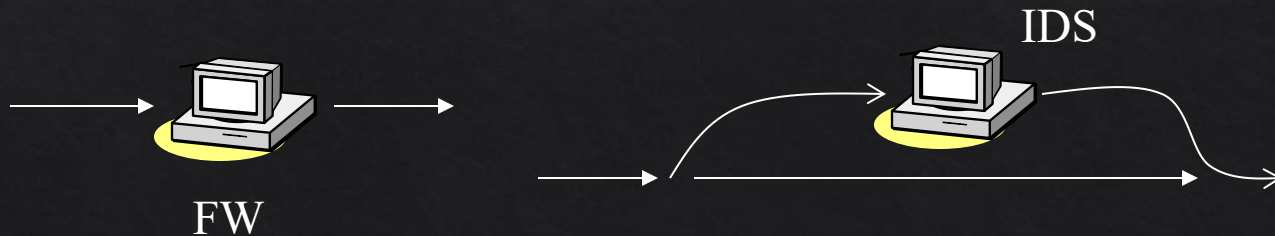
- ◇ Scalable
- ◇ Resilient to attacks

Monitoring Networks and Hosts



Firewall Versus Network IDS

- ◊ Firewall
 - ◊ Active filtering
 - ◊ Fail-close
- ◊ Network IDS
 - ◊ Passive monitoring
 - ◊ Fail-open



IDS Placement

- IDS placements – Host and Network

- HIDS (Host-based IDS)

- Sits inside the host system

- Monitor the system usage

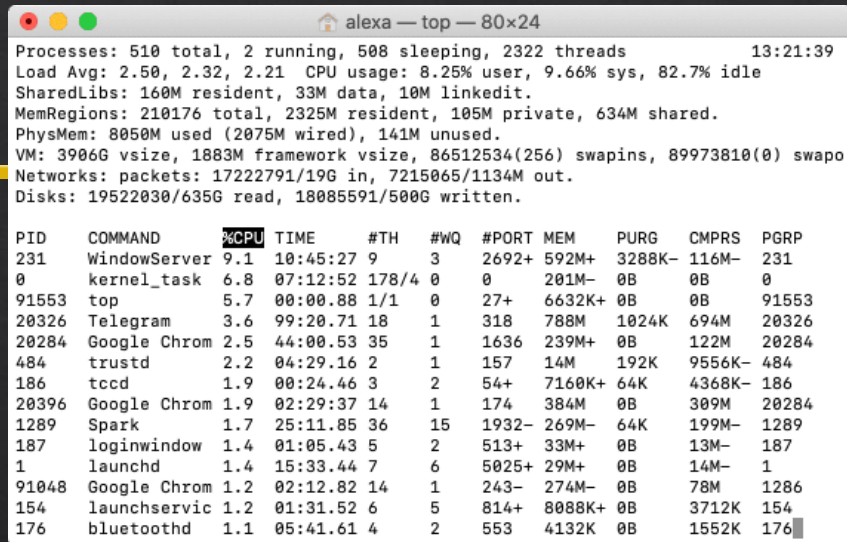
- OS dependent

- Application IDS also belongs here, but focuses on applications only

- NIDS (Network-based IDS)

- Sits in the network attached at a location

- Capture and monitor packets in the network



The screenshot shows a macOS terminal window titled 'alexa — top — 80x24'. The top section displays system statistics: Processes: 510 total, 2 running, 508 sleeping, 2322 threads; Load Avg: 2.50, 2.32, 2.21; CPU usage: 8.25% user, 9.66% sys, 82.7% idle; SharedLibs: 160M resident, 33M data, 10M linkedit; MemRegions: 210176 total, 2325M resident, 105M private, 634M shared; PhysMem: 8050M used (2075M wired), 141M unused; VM: 3906G vsize, 1883M framework vsize, 86512534(256) swapins, 89973810(0) swapo; Networks: packets: 17222791/19G in, 7215065/1134M out; Disks: 19522030/635G read, 18085591/500G written.

The bottom section shows the output of the 'top' command, listing processes with columns: PID, COMMAND, %CPU, TIME, #TH, #WQ, #PORT, MEM, PURG, CMPRS, and PGRP. The processes are sorted by CPU usage, with WindowServer at the top.

PID	COMMAND	%CPU	TIME	#TH	#WQ	#PORT	MEM	PURG	CMPRS	PGRP
231	WindowServer	9.1	10:45:27	9	3	2692+	592M+	3288K-	116M-	231
0	kernel_task	6.8	07:12:52	178/4	0	0	201M-	0B	0B	0
91553	top	5.7	00:00.88	1/1	0	27+	6632K+	0B	0B	91553
20326	Telegram	3.6	99:20.71	18	1	318	788M	1024K	694M	20326
20284	Google Chrom	2.5	44:00.53	35	1	1636	239M+	0B	122M	20284
484	trustrd	2.2	04:29.16	2	1	157	14M	192K	9556K-	484
186	tccd	1.9	00:24.46	3	2	54+	7160K+	64K	4368K-	186
20396	Google Chrom	1.9	02:29:37	14	1	174	384M	0B	309M	20284
1289	Spark	1.7	25:11.85	36	15	1932-	269M-	64K	199M-	1289
187	loginwindow	1.4	01:05.43	5	2	513+	33M+	0B	13M-	187
1	launchd	1.4	15:33.44	7	6	5025+	29M+	0B	14M-	1
91048	Google Chrom	1.2	02:12.82	14	1	243-	274M-	0B	78M	1286
154	launchservic	1.2	01:31.52	6	5	814+	8088K+	0B	3712K	154
176	bluetoothd	1.1	05:41.61	4	2	553	4132K	0B	1552K	176

NIDS

- ◇ Resides on computer or appliance connected to segment of an organization's network; looks for signs of attacks
 - ◇ <https://www.upguard.com/blog/top-free-network-based-intrusion-detection-systems-ids-for-the-enterprise> (open sourced NIDS tools e.g., suricata)
- ◇ When examining packets, a NIDS looks for attack patterns
- ◇ Installed at specific place in the network where it can watch traffic going into and out of particular network segment

NIDS Signature Matching

- ◇ NIDSs look for attack patterns for detection
- ◇ Accomplished via certain implementation of TCP/IP stack:
 - ◇ Protocol stack verification: look for invalid packets
 - ◇ App. Protocol verification: look at higher-order protocols for unexpected behaviour or improper use

NIDS Advantages & Disadvantages

Advantages

- Org. can monitor large network with few devices
- Passive; deployment minimally disrupts operations
- Less susceptible to attack; attackers may not detect them

Disadvantages

- Can be overwhelmed by volume of network traffic
- Need to monitor *all* traffic
- Usually, cannot analyse encrypted network packets
 - A malware download over HTTPS may appear as normal traffic
- Cannot determine if attack was successful
- Cannot detect some attacks (e.g., fragmented packets)
 - Malicious payload split across multiple packets

HIDS

- ◇ HIDS runs on a particular computer, monitors activity only on that system
- ◇ Benchmarks, monitors key system files; detects when intruders' file I/O
 - ◇ Event manager (Windows)
- ◇ HIDSs work on principle of configuration management
- ◇ Unlike NIDSs, HIDSs can be installed to access info. that's encrypted in transit over network

HIDS Advantages & Disadvantages

Advantages

- Detect local events, attacks on host systems that NIDSs may not
- Can view encrypted traffic (as it has been decrypted on system)
- HIDSs unaffected by switched network protocols
- Can detect inconsistencies in apps, programs by examining audit logs

Disadvantages

- Harder to manage than NIDSs
- Vulnerable to attacks against host operating system, HIDS
 - Attacker gains high-level privileges (e.g., root or administrator) can disable, modify, or blind the HIDS
- Cannot detect scans of multiple hosts, non-network devices
- HIDSs potential targets for denial-of-service (DoS) attack
- May use lots of disk space
- Possible large compute performance overhead on host systems

AppIDS

- ◇ Application-based IDS (AppIDS) looks at apps for abnormal events
- ◇ AppIDS may be configured to intercept requests:
 - ◇ File System
 - ◇ Network
 - ◇ Configuration
 - ◇ Process' Virtual Memory Address Space

AppIDS Advantages & Disadvantages

Advantages

- Aware of specific users; can observe interaction between apps and users
- Functions with encrypted incoming data

Disadvantages

- More susceptible to attack
- Less capable of detecting software tampering
- May be fooled by forms of spoofing

Current IDS direction

- ◇ The rise of machine learning (ML) has led IDS research and development based on ML techniques.
- ◇ Due to their effectiveness in terms of identifying anomalies in data, ML approaches became widely adopted technique for all IDS applications (network, host, application).
- ◇ However, practicality must be considered to ensure the IDS performance meets security requirements.

IDS in practice

- ◇ It is important to understand the suitability of different IDSes in practice, due to varying factors such as:
 - ◇ Environment (Enterprise network, Cloud, IoT, Industrial Control System): different Traffic patterns, Architectures and Constraints
 - ◇ Threat (External, insider attackers?)
 - ◇ Asset
 - ◇ Users
- ◇ To better understand the practicality of IDSes, they need to be evaluated.
- ◇ Q: How to evaluate IDSes?
 - ◇ i.e., how could you select the most appropriate IDS for your needs?

IDS in practice

- ◇ Users must be careful when choosing the right IDS, as they often have issues, such as:
 - ◇ Code errors
 - ◇ Dependency errors
 - ◇ Unavailability of tool/code
 - ◇ High resource requirements
 - ◇ Etc.

NIDS	Year	Dataset	Source	Usability/Issues
HELAD [24]	2020	CICIDS2017	Journal: MDPI Informatics	Used in this study
Multiclass Classification [28]	2020	ASNM Datasets	Conference: DSAA	Runtime errors
ARTEMIS. [29]	2021	Custom Dataset	Conference: LATINCOM	Code error
Dense-Attention-LSTM, DAL [30]	2021	UNSW-NB15	Conference: IWCMC	Dependency errors
I-SiamIDS [31]	2021	CICIDS, NSL-KDD	Journal: Applied Intelligence	Type error
SecureTea [32]	2021	N/A	GitHub	Dependency errors
Deep Belief Networks NIDS [33]	2022	CICIDS2017	Conference: SciSec	Dependency errors
RIDS [34]	2022	Custom Dataset	Conference: GLOBECOM	Runtime errors
StratosphereIPS (Slip) [27]	2022	N/A	GitHub	Used in this study
IDS-ML [35]	2022	CICIDS2017	Journal: Software Impacts	Runtime errors
xNIDS [36]	2023	Mirai, CICDoS2017, NSL-KDD	Conference: USENIX Security	Did not propose a directly usable NIDS, so was not appropriate.
Suricata [37]	2023	N/A	GitHub	Unable to verify any use of ML
AOC-IDS [25]	2024	NSL-KDD, UNSW-NB15	Conference: IEEE INFOCOM	Used in this study
LSVM-based IDSs [38]	2024	KDD CUP99, BotIoT, N-BaloT	Journal: Computers & Security	Runtime errors
Deep ResNIDS [39]	2024	CICIDS2017, CICIDS2018	Journal: Computers & Security	Lack of adequate preprocessing code
NEGSC [26]	2024	NF-BoT-IoT, NF-BoT-IoT-v2, NF-CSE-CIC-IDS2018, NF-CSE-CIC-IDS2018-v2	Journal: Computer Networks	Used in this study
SELKS [40]	2024	N/A	GitHub	Unable to verify any use of ML

IDS in practice

- ◇ Even when they work, you might not get the results you expected because:
 - ◇ Optimised for different use cases
 - ◇ Performs poorly on out-of-domain applications
 - ◇ Input incompatibility
 - ◇ Evolving threats
 - ◇ Etc.

Dataset	Acc.	Prec.	Rec.	F1
IDS: HELAD				
UNSW-NB15	0.9717	0.0201	0.0107	0.0140
BoT-IoT	0.9793	0.6916	0.9011	0.7826
CICIDS2017	0.6437	0.9682	0.3706	0.5360
CTU13	0.9846	0.9805	1.0000	0.9902
Mirai	0.8898	0.9939	0.8786	0.9327
Average:	0.8938	0.7284	0.6322	0.6511
IDS: Slip				
UNSW-NB15	0.4079	0.5778	0.2658	0.3641
BoT-IoT	0.1241	0.9988	0.1205	0.2150
CICIDS2017	0.7018	0.9920	0.1927	0.3227
CTU13	0.6745	0.8809	0.4739	0.6163
Mirai	0.8040	0.1243	0.0159	0.0282
Average:	0.5425	0.7148	0.2138	0.3093
IDS: AOC-IDS				
UNSW-NB15	0.8931	0.9060	0.9006	0.9028
BoT-IoT	0.5337	0.9997	0.5331	0.6868
CICIDS2017	0.3213	0.2581	0.9181	0.3971
CTU13	0.5262	0.5517	0.3590	0.4335
Mirai	0.5552	0.3980	0.3207	0.3394
Average:	0.5659	0.6227	0.6063	0.5519
IDS: NEGSC				
UNSW-NB15	0.8261	0.8166	0.8261	0.7970
BoT-IoT	0.9163	0.9164	0.9163	0.9163
CICIDS2017	0.9854	0.9860	0.9854	0.9854
CTU13	0.8685	0.8821	0.8685	0.8626
Mirai	0.6243	0.6151	0.6243	0.5123
Average:	0.8441	0.8432	0.8441	0.8147

***Bolded value**: the highest value of all IDSs for the metric column.

****Font colour blue**: the highest F1 score of all IDSs for the dataset.

Honeypot

- ◇ What are honeypots?
- ◇ Security resources that appear valuable but are isolated and monitored to detect, deflect, or study attack attempts
 - ◇ They function as decoy systems that mimic production environments
 - ◇ Designed to be probed, attacked and compromised (intentionally)
 - ◇ Collect data about attacker techniques and tools

<https://www.youtube.com/watch?v=W6HIkCijPZw>

Honeypot

Types of Honeypots

Low Interaction

- ◇ Simulates only basic services and protocols. Limited functionality but easier to be deployed and maintained. Over risk of compromise
- ◇ Honeyd
- ◇ Dionaea
- ◇ Cowrie (SSH/Telnet)

Medium Interaction

- ◇ Simulates more realistic services with deeper interaction capabilities. Balances security risk with data collection value.
- ◇ Kippo
- ◇ HoneyTrap
- ◇ SMTP Honeypots

High Interaction

- ◇ Real systems with minimal restrictions. Provides complete OS and services for attackers to interact with. Highest security risk but most valuable data
- ◇ HoneyNet Project
- ◇ Preal OS in isolated environment
- ◇ Customized vulnerable applications

Honeypot

Purposes of Honeypots

Production Honeypots

- ◆ Deployed together with production systems to enhance the security posture.
 - ◆ Early warning detection systems
 - ◆ Redirect attacks from real assets
 - ◆ Typically low to medium interaction
 - ◆ For practical defense not research

Research Honeypots

- ◆ Gather information about attack techniques, tools, and motivations of the threat actors
 - ◆ Collect comprehensive attack data
 - ◆ Study new malware and exploits
 - ◆ Often high-interaction systems
 - ◆ Used by security researchers and organizations

Honeypot

Purposes of Honeypots

Malware Honeypots

- ◇ Delicately designed to detect, capture, and analyze malware samples in the wild.
 - ◇ Capture malware binaries for analysis
 - ◇ Track infection vectors and techniques
 - ◇ Examples:
 - ◇ Thug
 - ◇ Cuckoo Sandbox

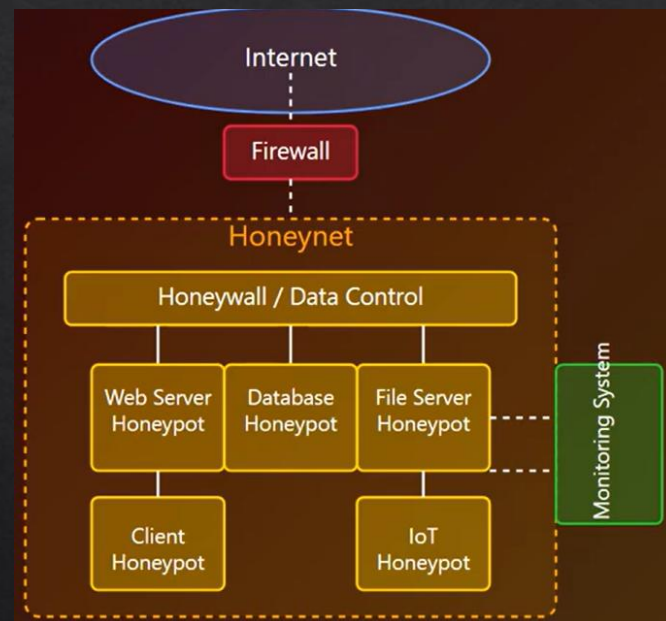
Client Honeypots

- ◇ Actively seek out malicious servers rather than waiting to be attacked (also called honeyclients)
 - ◇ Identify malicious websites and servers
 - ◇ Detect client-side attacks (browser exploits)
 - ◇ Proactive approach
 - ◇ Example
 - ◇ HoneyC
 - ◇ Capture-HPC

Honeynet

A honeynet is a network of honeypots designed to mimic a production network environment with multiple interconnected systems

- ◆ Network of multiple honeypots working together
- ◆ Simulates complex network infrastructure with various services
- ◆ Provides realistic network traffic and interactions
- ◆ Captures more sophisticated attack patterns and lateral movement
- ◆ Requires robust containment to prevent becoming a launch point for attacks



Honeynet

Deployment considerations

Security & Containment

- ◆ Implement strict network isolation
- ◆ Use data control systems to prevent outbound attacks
- ◆ Regular monitoring and maintenance
- ◆ Secure the monitoring infrastructure

Data Collection & Analysis

- ◆ Determine what data to collect
- ◆ Implement robust logging mechanisms
- ◆ Establish analysis procedures
- ◆ Consider storage requirements and retention policies

Honeynet

Deployment considerations

Legal & Ethical Considerations

- ◆ Review applicable laws and regulations
 - ◆ If your honeynet logs attacker keystrokes or payloads, this could be interpreted as surveillance without consent.
- ◆ Consider privacy implications
 - ◆ You're not just studying attacks—you're collecting real-world user data, which triggers privacy obligations.
- ◆ Implement appropriate banners/disclaims
 - ◆ Typical disclaimer message "This system is monitored for security purposes. Unauthorized use may be logged and reported."
- ◆ Consult legal counsel before deployment

Realism vs. Detection

- ◆ Balance between authenticity and security
 - ◆ If it's too real, attackers may: Fully compromise it; Use it as a pivot to attack other systems
- ◆ Avoid obvious honeypot signatures
 - ◆ Checking for: Default or empty file systems; No real user activity/history; Virtual machine artifacts (e.g., unusual hardware configs)
- ◆ Implement Realistic data and user behavior
 - ◆ A "dead" system is suspicious.
- ◆ Consider using active deception technologies
 - ◆ Honeynet/honeypot is often static

Conclusion

- ◇ Intrusion detection is one of the first key steps in identifying and mitigating threats.
- ◇ Several approaches are defined, all with benefits and limitations.
- ◇ Due to a large number of IDS tools available nowadays, it is important to consider the practical application that meets your requirements.
 - ◇ However, this turns out to be quite challenging, due to the lack of standardised evaluation of IDS solutions.
- ◇ Honeypot/Honeynet as typical deception techniques
- ◇ Further research must be carried out, and you may need to customise IDS solutions to meet your security requirements.

References

- ◇ Some figures from UC Berkley
- ◇ IDS comparisons
 - ◇ <https://doi.org/10.48550/arXiv.2403.17458>
- ◇ Signature-Based IDS vs Anomaly-Based IDS: Guide to Choose the Right Detection Model
 - ◇ <https://fidelissecurity.com/cybersecurity-101/learn/signature-based-vs-anomaly-based-ids/>